NIST Cybersecurity Framework Certification Report

MERGE

Valid for the period
September 16, 2024 - September 16, 2026

HITRUST®

Contents

1. The NIST Cybersecurity Framework Scorecard 3
2. Letter of NIST Cybersecurity Framework Certification 4
3. NIST Target and Current Profiles 6
4. HITRUST's NIST Cybersecurity Framework Scorecard 8

© 2024 HITRUST Alliance
HITRUSTAlliance.net

HITRUST

1. The NIST Cybersecurity Framework Scorecard

The NIST Cybersecurity Framework complements rather than replaces an organization's existing risk management process and cybersecurity program by providing an overarching set of guidelines to provide a minimal level of consistency as well as depth, breadth, and rigor of industry's cybersecurity programs, as shown in Figure 1.

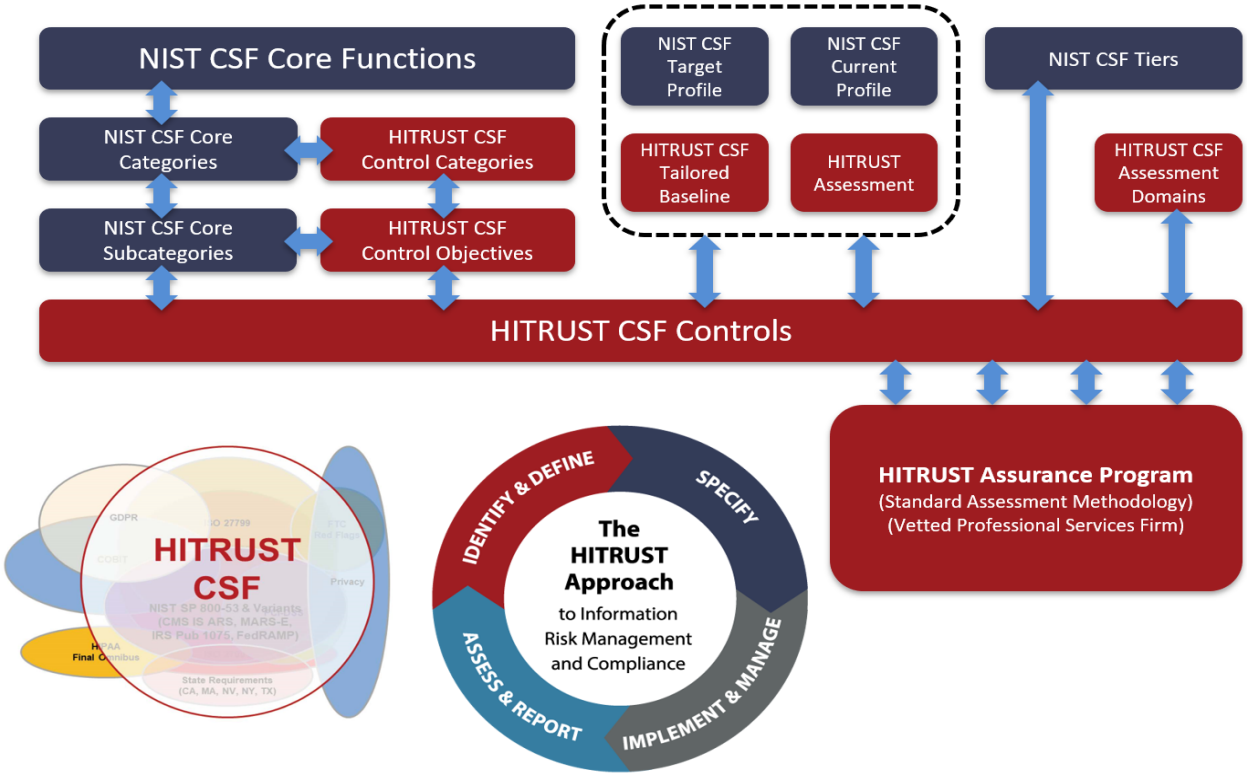

Figure 1. Implementing the NIST Cybersecurity Framework through the HITRUST CSF and CSF Assurance Program

The NIST Cybersecurity Framework Core is essentially a set of cybersecurity activities, desired outcomes, and applicable references that are common across government and industry. The Core presents industry standards, guidelines, and practices in a manner that allows for communication of cybersecurity activities and outcomes across an organization from the executive level to the implementation/operations level, from one organization to another, and from one industry to another.

NIST Cybersecurity Framework Core Functions provide an incident response and recovery-oriented view of an organization's cybersecurity needs; the NIST Cybersecurity Framework Core Categories provide topical groupings of cybersecurity activities related to each of the Core Functions; and the NIST Cybersecurity Framework Core Subcategories provide the specific outcomes intended for each Core Category.

© 2024 HITRUST Alliance
HITRUSTAlliance.net

2. Letter of NIST Cybersecurity Framework Certification

September 16, 2024

MERGE
200 E Randolph Street
Suite 3450
Chicago, Illinois 60601-6436

Based on the results of a HITRUST® Risk-based, 2-year (r2) Validated Assessment performed by an Authorized External Assessor and documented in a HITRUST Risk-based, 2-year (r2) Validated Assessment Report ("Report"), the following platform, facility, and supporting infrastructure of the Organization ("Scope") is supported by an information protection program that is consistent with the objectives specified in the NIST Cybersecurity Framework v1.1:

Platform:

- MERGE Marketing Solution residing at Google Workspaces

Facility:

- Google Workspaces (Data Center) managed by Google Cloud located in N/a, Multiple, United States of America

More specifically, HITRUST determined that:

- The HITRUST CSF controls specified by the Entity's organizational, system and regulatory risk factors provide a fair representation of its Target Profile, and
- The maturity of the Entity's implemented HITRUST CSF controls, as validated by an Authorized External Assessor and reflected in the HITRUST Scorecard for the NIST Cybersecurity Framework, provide a fair representation of its Current Profile, and
- The aggregated maturity scores for each of the Core Categories meet HITRUST's criteria for certification of the Scope addressed by the assessment.

This certification is valid for as long as the Entity's associated HITRUST Risk-based, 2-year (r2) Certification remains valid but shall not exceed a period of two years from the date of this letter.

A full copy of the HITRUST Risk-based, 2-year (r2) Certification Report has been issued to the organization listed above. The full Report contains detailed information relating to the effectiveness of information protection controls as defined by the scoping factors selected by

© 2024 HITRUST Alliance
HITRUSTAlliance.net

management. It also includes further details on the scope of the assessment, a representation letter from management, testing results, a benchmark report comparing the Organization's results to industry results, details on corrective action plans identified if applicable, and the completed questionnaire. Such detailed information can best be leveraged by individuals/organizations who are familiar with and understand the services provided by the organization listed above. If interested in obtaining a copy of the full Report, you will need to contact the Organization directly. If there are questions on interpreting the detailed contents found in the full report, please refer to the document *Leveraging HITRUST Assessment Reports: A Guide for New Users* and can contact HITRUST customer support at *support@hitrustalliance.net.*

Additional information on the HITRUST Assurance Program used to support HITRUST's certification of the NIST Cybersecurity Framework can be found on the HITRUST website: *https://hitrustalliance.net.*

HITRUST

HITRUST

© 2024 HITRUST Alliance
HITRUSTAlliance.net

3. NIST Target and Current Profiles

The HITRUST CSF and HITRUST Assurance Program directly support an organization's implementation of the NIST Cybersecurity Framework by specifying the controls required for its Target Profile and the assessment methodology used to provide reliable assurances about its Current Profile. Figure 2 below depicts the Organization's Target Profile viewed through the lens of the HITRUST CSF control implementation levels and industry segments. The Target Profile specifies an industry acceptable level of due care for the protection of sensitive information as determined by its organizational, system and regulatory risk factors.

0 - ISMS	01 - Access Control																										02 - Human Resources Security									03 - Risk Management				04 - Security Policy	
00.a	01.a	01.b	01.c	01.d	01.e	01.f	01.g	01.h	01.i	01.j	01.k	01.l	01.m	01.n	01.o	01.p	01.q	01.r	01.s	01.t	01.u	01.v	01.w	01.x	01.y	02.a	02.b	02.c	02.d	02.e	02.f	02.g	02.h	02.i	03.a	03.b	03.c	03.d	04.a	04.b
1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1
		2	2	2	2											2	2	2	2			2	2																	
																3						3																		

05 - Organization of Information Security											06 - Compliance										07 - Asset Management					08 - Physical and Environmental Security													
05.a	05.b	05.c	05.d	05.e	05.f	05.g	05.h	05.i	05.j	05.k	06.a	06.b	06.c	06.d	06.e	06.f	06.g	06.h	06.i	06.j	07.a	07.b	07.c	07.d	07.e	08.a	08.b	08.c	08.d	08.e	08.f	08.g	08.h	08.i	08.j	08.k	08.l	08.m
1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1

09 - Communications and Operations Management																															
09.a	09.aa	09.ab	09.ac	09.ad	09.ae	09.af	09.b	09.c	09.d	09.e	09.f	09.g	09.h	09.i	09.j	09.k	09.l	09.m	09.n	09.o	09.p	09.q	09.r	09.s	09.t	09.u	09.v	09.w	09.x	09.y	09.z
1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1
	2	2	2		2	2	2		2	2	2	2	2	2																	

10 - Information Systems Acquisition, Development, and Maintenance													11 - Information Security					12 - Business Continuity					13 - Privacy Practices																		
10.a	10.b	10.c	10.d	10.e	10.f	10.g	10.h	10.i	10.j	10.k	10.l	10.m	11.a	11.b	11.c	11.d	11.e	12.a	12.b	12.c	12.d	12.e	13.a	13.b	13.c	13.d	13.e	13.f	13.g	13.h	13.i	13.j	13.k	13.l	13.m	13.n	13.o	13.p	13.q	13.r	13.s	13.t	13.u
1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1
	2	2		2			2	2	2																																

Color Legend

Denotes a control required for r2

Figure 2. Target Profile - HITRUST CSF Controls

© 2024 HITRUST Alliance
HITRUSTAlliance.net

The Organization's Current Profile, depicted in Figure 3 below, is determined by the HITRUST Risk-based, 2-year (r2) Validated Assessment used to support HITRUST Risk-based, 2-year (r2) Certification, which is based on a purposive sample of 75 security controls contained in the HITRUST CSF framework. The sample ensures the assessment provides relying parties reasonable assurances about an organization's implementation of the HIPAA Security Rule standards and implementation specifications; AICPA Trust Services Criteria for Security, Confidentiality and Availability; and NIST Cybersecurity Framework Core Subcategories at a reasonable cost to the assessed organization.

0 - ISMS	01 - Access Control																									02 - Human Resources Security									03 - Risk Management				04 - Security	
00.a	01.a	01.b	01.c	01.d	01.e	01.f	01.g	01.h	01.i	01.j	01.k	01.l	01.m	01.n	01.o	01.p	01.q	01.r	01.s	01.t	01.u	01.v	01.w	01.x	01.y	02.a	02.b	02.c	02.d	02.e	02.f	02.g	02.h	02.i	03.a	03.b	03.c	03.d	04.a	04.b
1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1
		2	2	2	2											2	2	2	2			2	2																	
																3						3																		

05 - Organization of Information Security											06 - Compliance										07 - Asset Management					08 - Physical and Environmental Security												
05.a	05.b	05.c	05.d	05.e	05.f	05.g	05.h	05.i	05.j	05.k	06.a	06.b	06.c	06.d	06.e	06.f	06.g	06.h	06.i	06.j	07.a	07.b	07.c	07.d	07.e	08.a	08.b	08.c	08.d	08.e	08.f	08.g	08.h	08.i	08.j	08.k	08.l	08.m
1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1

09 - Communications and Operations Management																																					
09.a	09.aa	09.ab	09.ac	09.ad	09.ae	09.af	09.b	09.c	09.d	09.e	09.f	09.g	09.h	09.i	09.j	09.k	09.l	09.m	09.n	09.o	09.p	09.q	09.r	09.s	09.t	09.u	09.v	09.w	09.x	09.y	09.z
1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1
	2	2	2		2	2	2		2	2	2	2	2	2																	

10 - Information Systems Acquisition, Development, and Maintenance													11 - Information Security					12 - Business Continuity					13 - Privacy Practices																			
10.a	10.b	10.c	10.d	10.e	10.f	10.g	10.h	10.i	10.j	10.k	10.l	10.m	11.a	11.b	11.c	11.d	11.e	12.a	12.b	12.c	12.d	12.e	13.a	13.b	13.c	13.d	13.e	13.f	13.g	13.h	13.i	13.j	13.k	13.l	13.m	13.n	13.o	13.p	13.q	13.r	13.s	13.t	13.u
1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1	1
	2	2		2			2	2	2																																		

Color Legend

Denotes a control required for r2 | Meets | N/A | Requirements partially

Figure 3. Current Profile - HITRUST CSF Controls (Purposive Sample)

Note more robust assurances, if needed, can be provided through a comprehensive assessment of all 135 HITRUST CSF security controls, as scoped by the Organization's risk factors.

© 2024 HITRUST Alliance
HITRUSTAlliance.net

4. HITRUST's NIST Cybersecurity Framework Scorecard

Although the Organization's Target and Current Profiles are expressed in terms of the HITRUST CSF controls, HITRUST certification of the Organization's NIST Cybersecurity Framework implementation is based on the NIST Cybersecurity Framework v1.1 Core and presented via HITRUST's NIST Cybersecurity Framework Scorecard. This Scorecard, presented in Figure 4 beginning on the next page, reflects the aggregated scores for the underlying HITRUST CSF controls as they are mapped by HITRUST to the NIST Cybersecurity Framework Core Subcategories. While HITRUST does its best to ensure the appropriate HITRUST CSF controls are mapped to each of the NIST Cybersecurity Framework v1.1 requirements, we make no representations around the suitability of the mappings as NIST might interpret them.

For more information on the HITRUST approach to assessment and certification, refer to the Risk Analysis Guide for HITRUST Organizations and Assessors, available from *https://hitrustalliance.net/documents/csf_rmf_related/RiskAnalysisGuide.pdf.*

More information about the controls framework-based approach to risk analysis and the HITRUST CSF as an industry overlay of the NIST SP 800-53 moderate-level baseline can be found in the document entitled Understanding HITRUST's Approach to Risk vs. Compliance-based Information Protection, available from *https://hitrustalliance.net/documents/csf_rmf_related/RiskVsComplianceWhitepaper.pdf.*

More information on how the HITRUST CSF is used to facilitate an organization's implementation of the NIST Cybersecurity Framework can be found in the Healthcare Sector Cybersecurity Framework Implementation Guide, available on the US CERT Cybersecurity Framework Website at *https://www.us-cert.gov/ccubedvp/cybersecurity-framework.* (Note the HITRUST CSF can be used to facilitate NIST Cybersecurity Framework implementation for any organization, regardless of industry.)

Scorecard Color Legend

Not applicable to the assessment
Requirements met (Avg. score of mapped HITRUST CSF requirements: 70-79.9)
Requirements partially met (Avg. score of mapped HITRUST CSF requirements: 60-69.9)

© 2024 HITRUST Alliance
HITRUSTAlliance.net

Function	Status	Category	Status	Subcategory	Status
Identify (ID)		**Asset Management (ID.AM):** The data, personnel, devices, systems, and facilities that enable the organization to achieve business purposes are identified and managed consistent with their relative importance to organizational objectives and the organization's risk strategy.		**ID.AM-1:** Physical devices and systems within the organization are inventoried	
				ID.AM-2: Software platforms and applications within the organization are inventoried	
				ID.AM-3: Organizational communication and data flows are mapped	
				ID.AM-4: External information systems are catalogued	
				ID.AM-5: Resources (e.g., hardware, devices, data, time, personnel, and software) are prioritized based on their classification, criticality, and business value	
				ID.AM-6: Cybersecurity roles and responsibilities for the entire workforce and third-party stakeholders (e.g., suppliers, customers, partners) are established	
		Business Environment (ID.BE): The organization's mission, objectives, stakeholders, and activities are understood and prioritized; this information is used to inform cybersecurity roles, responsibilities, and risk management decisions.		**ID.BE-1:** The organization's role in the supply chain is identified and communicated	
				ID.BE-2: The organization's place in critical infrastructure and its industry sector is identified and communicated	
				ID.BE-3: Priorities for organizational mission, objectives, and activities are established and communicated	
				ID.BE-4: Dependencies and critical functions for delivery of critical services are established	
				ID.BE-5: Resilience requirements to support delivery of critical services are established for all operating states (e.g. under duress/attack, during recovery, normal operations)	
		Governance (ID.GV): The policies, procedures, and processes to manage and monitor the		**ID.GV-1:** Organizational cybersecurity policy is established and communicated	
				ID.GV-2: Cybersecurity roles and responsibilities are coordinated and aligned with internal roles and external partners	

© 2024 HITRUST Alliance
HITRUSTAlliance.net

Function	Status	Category	Status	Subcategory	Status
		organization's regulatory, legal, risk, environmental, and operational requirements are understood and inform the management of cybersecurity risk.		**ID.GV-3:** Legal and regulatory requirements regarding cybersecurity, including privacy and civil liberties obligations, are understood and managed	
				ID.GV-4: Governance and risk management processes address cybersecurity risks	
		Risk Assessment (ID.RA): The organization understands the cybersecurity risk to organizational operations (including mission, functions, image, or reputation), organizational assets, and individuals.		**ID.RA-1:** Asset vulnerabilities are identified and documented	
				ID.RA-2: Cyber threat intelligence is received from information sharing forums and sources	
				ID.RA-3: Threats, both internal and external, are identified and documented	
				ID.RA-4: Potential business impacts and likelihoods are identified	
				ID.RA-5: Threats, vulnerabilities, likelihoods, and impacts are used to determine risk	
				ID.RA-6: Risk responses are identified and prioritized	
		Risk Management Strategy (ID.RM): The organization's priorities, constraints, risk tolerances, and assumptions are established and used to support operational risk decisions.		**ID.RM-1:** Risk management processes are established, managed, and agreed to by organizational stakeholders	
				ID.RM-2: Organizational risk tolerance is determined and clearly expressed	
				ID.RM-3: The organization's determination of risk tolerance is informed by its role in critical infrastructure and sector specific risk analysis	
		Supply Chain Risk Management (ID.SC): The organization's		**ID.SC-1:** Cyber supply chain risk management processes are identified, established, assessed, managed, and agreed to by organizational stakeholders	

© 2024 HITRUST Alliance
HITRUSTAlliance.net

Function	Status	Category	Status	Subcategory	Status
		priorities, constraints, risk tolerances, and assumptions are established and used to support risk decisions associated with managing supply chain risk. The organization has established and implemented the processes to identify, assess and manage supply chain risks.		**ID.SC-2:** Suppliers and third party partners of information systems, components, and services are identified, prioritized, and assessed using a cyber supply chain risk assessment process	
				ID.SC-3: Contracts with suppliers and third-party partners are used to implement appropriate measures designed to meet the objectives of an organization's cybersecurity program and Cyber Supply Chain Risk Management Plan.	
				ID.SC-4: Suppliers and third-party partners are routinely assessed using audits, test results, or other forms of evaluations to confirm they are meeting their contractual obligations.	
				ID.SC-5: Response and recovery planning and testing are conducted with suppliers and third-party providers	
Protect (PR)		**Identity Management, Authentication and Access Control (PR.AC):** Access to physical and logical assets and associated facilities is limited to authorized users, processes, and devices, and is managed consistent with the assessed risk of unauthorized access to authorized activities and transactions.		**PR.AC-1:** Identities and credentials are issued, managed, verified, revoked, and audited for authorized devices, users and processes	
				PR.AC-2: Physical access to assets is managed and protected	
				PR.AC-3: Remote access is managed	
				PR.AC-4: Access permissions and authorizations are managed, incorporating the principles of least privilege and separation of duties	
				PR.AC-5: Network integrity is protected (e.g., network segregation, network segmentation)	
				PR.AC-6: Identities are proofed and bound to credentials and asserted in interactions	
				PR.AC-7: Users, devices, and other assets are authenticated (e.g., single-factor, multi-factor) commensurate with the risk of the transaction (e.g., individuals' security and privacy risks and other organizational risks)	
				PR.AT-1: All users are informed and trained	

© 2024 HITRUST Alliance
HITRUSTAlliance.net

Function	Status	Category	Status	Subcategory	Status
		Awareness and Training (PR.AT): The organization's personnel and partners are provided cybersecurity awareness education and are trained to perform their cybersecurity-related duties and responsibilities consistent with related policies, procedures, and agreements.		**PR.AT-2:** Privileged users understand their roles and responsibilities	
				PR.AT-3: Third-party stakeholders (e.g., suppliers, customers, partners) understand their roles and responsibilities	
				PR.AT-4: Senior executives understand their roles and responsibilities	
				PR.AT-5: Physical and cybersecurity personnel understand their roles and responsibilities	
		Data Security (PR.DS): Information and records (data) are managed consistent with the organization's risk strategy to protect the confidentiality, integrity, and availability of information.		**PR.DS-1:** Data-at-rest is protected	
				PR.DS-2: Data-in-transit is protected	
				PR.DS-3: Assets are formally managed throughout removal, transfers, and disposition	
				PR.DS-4: Adequate capacity to ensure availability is maintained	
				PR.DS-5: Protections against data leaks are implemented	
				PR.DS-6: Integrity checking mechanisms are used to verify software, firmware, and information integrity	
				PR.DS-7: The development and testing environment(s) are separate from the production environment	
				PR.DS-8: Integrity checking mechanisms are used to verify hardware integrity	
		Information Protection Processes and Procedures (PR.IP): Security policies (that address purpose, scope, roles, responsibilities,		**PR.IP-1:** A baseline configuration of information technology/industrial control systems is created and maintained incorporating security principles (e.g. concept of least functionality)	
				PR.IP-2: A System Development Life Cycle to manage systems is implemented	

© 2024 HITRUST Alliance
HITRUSTAlliance.net

Function	Status	Category	Status	Subcategory	Status
		management commitment, and coordination among organizational entities), processes, and procedures are maintained and used to manage protection of information systems and assets.		**PR.IP-3:** Configuration change control processes are in place	
				PR.IP-4: Backups of information are conducted, maintained, and tested	
				PR.IP-5: Policy and regulations regarding the physical operating environment for organizational assets are met	
				PR.IP-6: Data is destroyed according to policy	
				PR.IP-7: Protection processes are improved	
				PR.IP-8: Effectiveness of protection technologies is shared	
				PR.IP-9: Response plans (Incident Response and Business Continuity) and recovery plans (Incident Recovery and Disaster Recovery) are in place and managed	
				PR.IP-10: Response and recovery plans are tested	
				PR.IP-11: Cybersecurity is included in human resources practices (e.g., deprovisioning, personnel screening)	
				PR.IP-12: A vulnerability management plan is developed and implemented	
		Maintenance (PR.MA): Maintenance and repairs of industrial control and information system components are performed consistent with policies and procedures.		**PR.MA-1:** Maintenance and repair of organizational assets are performed and logged, with approved and controlled tools	
				PR.MA-2: Remote maintenance of organizational assets is approved, logged, and performed in a manner that prevents unauthorized access	
		Protective Technology (PR.PT): Technical security solutions are managed to ensure the security and resilience of systems and assets, consistent with related		**PR.PT-1:** Audit/log records are determined, documented, implemented, and reviewed in accordance with policy	
				PR.PT-2: Removable media is protected and its use restricted according to policy	
				PR.PT-3: The principle of least functionality is incorporated by configuring systems to provide only essential capabilities	
				PR.PT-4: Communications and control networks are protected	

© 2024 HITRUST Alliance
HITRUSTAlliance.net

Function	Status	Category	Status	Subcategory	Status
		policies, procedures, and agreements.		**PR.PT-5:** Mechanisms (e.g., failsafe, load balancing, hot swap) are implemented to achieve resilience requirements in normal and adverse situations	
Detect (DE)		**Anomalies and Events (DE.AE):** Anomalous activity is detected and the potential impact of events is understood.		**DE.AE-1:** A baseline of network operations and expected data flows for users and systems is established and managed	
				DE.AE-2: Detected events are analyzed to understand attack targets and methods	
				DE.AE-3: Event data are collected and correlated from multiple sources and sensors	
				DE.AE-4: Impact of events is determined	
				DE.AE-5: Incident alert thresholds are established	
		Security Continuous Monitoring (DE.CM): The information system and assets are monitored to identify cybersecurity events and verify the effectiveness of protective measures.		**DE.CM-1:** The network is monitored to detect potential cybersecurity events	
				DE.CM-2: The physical environment is monitored to detect potential cybersecurity events	
				DE.CM-3: Personnel activity is monitored to detect potential cybersecurity events	
				DE.CM-4: Malicious code is detected	
				DE.CM-5: Unauthorized mobile code is detected	
				DE.CM-6: External service provider activity is monitored to detect potential cybersecurity events	
				DE.CM-7: Monitoring for unauthorized personnel, connections, devices, and software is performed	
				DE.CM-8: Vulnerability scans are performed	
		Detection Processes (DE.DP): Detection processes and procedures are maintained and tested to		**DE.DP-1:** Roles and responsibilities for detection are well defined to ensure accountability	
				DE.DP-2: Detection activities comply with all applicable requirements	
				DE.DP-3: Detection processes are tested	
				DE.DP-4: Event detection information is communicated	

© 2024 HITRUST Alliance
HITRUSTAlliance.net

Function	Status	Category	Status	Subcategory	Status
		ensure awareness of anomalous events.		**DE.DP-5:** Detection processes are continuously improved	
Respond (RS)		**Response Planning (RS.RP):** Response processes and procedures are executed and maintained, to ensure response to detected cybersecurity incidents.		**RS.RP-1:** Response plan is executed during or after an incident	
		Communications (RC.CO): Restoration activities are coordinated with internal and external parties (e.g. coordinating centers, Internet Service Providers, owners of attacking systems, victims, other CSIRTs, and vendors).		**RS.CO-1:** Personnel know their roles and order of operations when a response is needed	
				RS.CO-2: Incidents are reported consistent with established criteria	
				RS.CO-3: Information is shared consistent with response plans	
				RS.CO-4: Coordination with stakeholders occurs consistent with response plans	
				RS.CO-5: Voluntary information sharing occurs with external stakeholders to achieve broader cybersecurity situational awareness	
		Analysis (RS.AN): Analysis is conducted to ensure effective response and support recovery activities.		**RS.AN-1:** Notifications from detection systems are investigated	
				RS.AN-2: The impact of the incident is understood	
				RS.AN-3: Forensics are performed	
				RS.AN-4: Incidents are categorized consistent with response plans	
				RS.AN-5: Processes are established to receive, analyze and respond to vulnerabilities disclosed to the organization from internal and external sources (e.g. internal testing, security bulletins, or security researchers)	
		Mitigation (RS.MI): Activities are performed		**RS.MI-1:** Incidents are contained	
				RS.MI-2: Incidents are mitigated	

© 2024 HITRUST Alliance
HITRUSTAlliance.net

Function	Status	Category	Status	Subcategory	Status
		to prevent expansion of an event, mitigate its effects, and resolve the incident.		**RS.MI-3:** Newly identified vulnerabilities are mitigated or documented as accepted risks	
		Improvements (RS.IM): Organizational response activities are improved by incorporating lessons learned from current and previous detection/response activities.		**RS.IM-1:** Response plans incorporate lessons learned	
				RS.IM-2: Response strategies are updated	
Recover (RC)		**Recovery Planning (RC.RP):** Recovery processes and procedures are executed and maintained to ensure restoration of systems or assets affected by cybersecurity incidents.		**RC.RP-1:** Recovery plan is executed during or after a cybersecurity incident	
		Improvements (RC.IM): Recovery planning and processes are improved by incorporating lessons learned into future activities.		**RC.IM-1:** Recovery plans incorporate lessons learned	
				RC.IM-2: Recovery strategies are updated	
		Communications (RS.CO): Response		**RC.CO-1:** Public relations are managed	
				RC.CO-2: Reputation is repaired after an incident	

© 2024 HITRUST Alliance
HITRUSTAlliance.net

Function	Status	Category	Status	Subcategory	Status
		activities are coordinated with internal and external stakeholders (e.g. external support from law enforcement agencies).		**RC.CO-3:** Recovery activities are communicated to internal and external stakeholders as well as executive and management teams	

Figure 4. HITRUST Scorecard for the NIST Cybersecurity Framework

© 2024 HITRUST Alliance
HITRUSTAlliance.net